KHATUPAY

Security Implementation Report

A source-level review of the security controls implemented across the KhatuPay platform - mobile app, backend API, and admin panel.

Application	KhatuPay (com.finance.khatupay)
Scope	Mobile app (Flutter/Android), backend API (Node.js/Express), admin panel
Report date	20 August 2026
Prepared by	KhatuPay Engineering Team
Review basis	Direct source-code review of the current codebase (not binary decompilation)

KhatuPay - Confidential. Prepared for client review. Not for public redistribution.

1. Overview

This report documents the security controls that are implemented today in the KhatuPay platform, following a full source-level review of the authentication system, payment flows, KYC/data-handling paths, and mobile app configuration. Unlike a black-box review of a compiled app binary, this assessment was done directly against the running source code, so every item below reflects the actual current behaviour of the system rather than an inference from decompiled output.

Security work at KhatuPay is treated as ongoing rather than a one-time checklist. This report is deliberately balanced: it states plainly what is implemented and verified, and it is equally explicit about the small number of items that are in progress or planned, rather than presenting an all-green picture. We believe that transparency is itself part of a credible security posture.

12+	3	0
CONTROLS IMPLEMENTED & VERIFIED	HARDENING ITEMS IN PROGRESS	KNOWN UNRESOLVED CRITICAL ISSUES

2. Implementation Status Summary

AREA	STATUS	SUMMARY
Transport security (HTTPS-only)	Implemented	Cleartext HTTP disabled app-wide; no development/LAN hosts in production builds.
Credential storage	Implemented	Passwords and MPINs are bcrypt-hashed; plaintext credentials are never stored.
Login & PIN brute-force protection	Implemented	Account lockout after repeated failed attempts, plus request-rate limiting on all authentication endpoints.
Session & token revocation	Implemented	Short-lived access tokens; refresh tokens can be invalidated server-side on password/PIN reset or explicit logout-everywhere.
Payment amount integrity	Implemented	Loan repayment amounts are computed server-side from the loan's own schedule, never trusted from the client.
Payment signature verification	Implemented	Razorpay payments are cryptographically verified before being marked confirmed.
KYC identity verification	Implemented	Aadhaar OTP e-KYC and PAN name verification via a licensed data provider; Aadhaar numbers are masked wherever displayed.
OTP handling	Implemented	OTPs are hashed at rest, expire automatically, and are capped on verification attempts.
Error handling	Implemented	Users see plain-language error messages; internal error/stack detail is never exposed to the client.
Admin audit trail	Implemented	Sensitive admin actions (password/PIN resets, KYC decisions) are written to an audit log with actor and timestamp.
Device backup exposure	Implemented	Android auto-backup is disabled, so app data cannot be extracted via device/ADB backup.
Payment gateway configuration	Implemented	No placeholder or fallback payment keys are shipped; the app always uses the key issued by the server for that specific order.
TLS certificate pinning	In progress	Network layer is HTTPS-only today; pinning is being added once the production certificate is finalised.

AREA	STATUS	SUMMARY
Device attestation (Play Integrity)	Planned	Root/tamper/emulator attestation via Google Play Integrity API, pending Play Console configuration.
Firebase project hardening	Planned	Firebase App Check and Android-package API key restriction, pending Firebase console configuration.

3. Network & Transport Security

HTTPS enforced end-to-end

- The Android app's network security configuration permits cleartext (unencrypted) traffic to no domain. Every request from the app to the KhatuPay API travels over HTTPS.
- Development/debug hosts (e.g. a local LAN address used during development) have been removed from the production configuration and are no longer reachable from released builds.
- All API traffic is authenticated using short-lived bearer tokens transmitted only over TLS.

In progress: certificate pinning

Certificate pinning adds a second layer of protection against interception even if a device's trusted certificate store is compromised (for example, a malicious profile on a shared or managed device). The network layer is fully HTTPS today; pinning is being finalised against the production certificate and will ship in an upcoming release.

4. Authentication & Session Security

Credential storage

- Account passwords and 4-digit transaction MPINs are hashed with bcrypt before being stored; the application never stores or logs credentials in plaintext.
- One-time passcodes (email verification, password reset, PIN reset, Aadhaar OTP) are likewise hashed at rest and are single-use, time-expiring, and capped at a limited number of verification attempts before being invalidated.

Brute-force protection

- Repeated incorrect MPIN attempts lock the account for a cool-down period after a small, fixed number of failures.
- All authentication endpoints (login, registration, password/PIN reset, refresh) are rate-limited per client, with a tighter limit specifically on credential-guessing endpoints.
- Aadhaar OTP send/verify endpoints carry their own independent rate limit, in addition to requiring an authenticated session.

Session lifecycle & revocation

- Access tokens are short-lived. Longer-lived refresh tokens are used to silently renew a session without requiring the user to log in repeatedly.
- Refresh tokens can be revoked server-side: resetting a password or PIN (by the user or by an administrator) or explicitly signing out of all devices immediately invalidates every outstanding refresh token for that account, closing the window in which a copied or leaked token could otherwise be reused.
- The mobile app additionally signs the user out automatically after a period of inactivity, independent of the server-side controls above.

5. Payment & Financial Integrity

Server-derived amounts for loan repayment

Loan repayment amounts - whether a single instalment or a full loan closure - are calculated by the server directly from that loan's own repayment schedule at the moment a payment order is created. The amount is never taken as-is from the requesting client. This prevents a manipulated request from closing out a loan, or an instalment, for less than what is actually owed.

Payment verification

- Every Razorpay payment is cryptographically verified (HMAC signature check) against the order before being marked as confirmed; unverified callbacks are rejected.
- If a recharge or bill payment is collected successfully but the downstream biller/operator transaction fails, the amount is automatically refunded or credited back to the customer's wallet, with the outcome recorded and the customer notified.
- Wallet, peer-to-peer, recharge, and bill-payment amounts remain user-specified by design (there is no "correct" server-known amount for these), and are bounded to sane minimum/maximum limits.

6. KYC & Sensitive Data Handling

Identity verification

- Aadhaar identity is verified through an OTP-based offline e-KYC flow against a licensed verification provider; Aadhaar numbers are masked in every place they are displayed, both in the app and in the admin panel.
- PAN details are verified against the registered holder's name before being accepted, both during KYC and during loan applications.
- KYC documents (photo IDs, selfies, income proof) are uploaded directly to secure cloud storage rather than retained on the device or transmitted unencrypted.

Administrative access control

- Full KYC detail (verified identity data, uploaded documents) is visible only to authenticated administrators through the admin panel, which is gated by role-based access control separate from the customer-facing app.
- Every KYC approval/rejection and every administrator-initiated password or PIN reset is written to an audit log recording who performed the action and when.

7. Application Hardening

- **No exposed payment misconfiguration.** The app does not ship with a fallback or placeholder payment key; if the server-issued key is ever unavailable, checkout fails with a clear message rather than silently attempting a non-functional payment.
- **Device backup disabled.** Android's automatic app-data backup is turned off, so app data cannot be extracted through a device or ADB backup.
- **User-facing errors are sanitised.** Validation and server errors are translated into plain-language messages before reaching the user; database errors, stack traces, and other internal detail are logged server-side only and never returned in an API response.
- **Experimental/unreleased features are inert in production.** Features still pending third-party partner approval are present in the codebase (to avoid re-building them later) but are not reachable through the live app's navigation - users see a "coming soon" state instead.

8. Ongoing Hardening Roadmap

The following items are recognised, scoped, and either in progress or planned. None are known to be currently exploited, and none block normal operation of the app; they represent additional layers of defence being added on top of the controls already in place.

ITEM	STATUS	WHAT IT ADDS
TLS certificate pinning	In progress	Defends against interception even if a device's certificate trust store is compromised.
Google Play Integrity attestation	Planned	Detects rooted devices, emulators, and tampered/repackaged app builds at runtime.
Firebase App Check + API key restriction	Planned	Restricts Firebase API usage to genuine, unmodified KhatuPay app installs.

9. Summary

KhatuPay's authentication, session, payment-integrity, and KYC-handling paths implement the controls described above, verified directly against the current source code as of the report date. The three items in Section 8 are the team's current hardening priorities and will be closed out in upcoming releases. We are happy to walk through any part of this report, or to share further technical detail under NDA, on request.

KhatuPay - Confidential. This document summarises security controls as implemented in the reviewed codebase on the date above and does not constitute a formal third-party penetration test or certification. It is intended to give the recipient an accurate, good-faith picture of current implementation status for review purposes.